

Mapeo detallado de preguntas GQM a requisitos normativos

Este documento vincula las preguntas GQM asociadas a los indicadores M1–M5 con requisitos normativos relevantes (NIS2, obligaciones de notificación y estrategias nacionales). [web:7][web:13][web:12]

1. Tabla de mapeo GQM–Normativa

Leyenda de objetivos y métricas

- Objetivos: G1 (Exposición), G2 (Ventana explotable), G3 (Servicios esenciales), G4 (Alineamiento regulatorio).
- Métricas: M1–M5, según la matriz PRAGMATIC.

Tabla principal

Código Pregunta	Pregunta GQM	Objetivo GQM	Métrica(s) asociada(s)	Referencia normativa UE / nacional	Comentario de alineamiento
Q1-G1-EXP	¿Cuál es la proporción de sistemas expuestos a Internet con vulnerabilidades de alta severidad según CVSS v4.0?	G1	M1	NIS2 – obligaciones de gestión de riesgos y medidas técnicas organizativas; Estrategia Nacional de Ciberseguridad	La gestión de vulnerabilidades en sistemas expuestos es parte esencial de las medidas de seguridad exigidas. [web:7] [web:12]
Q2-G1-SECT	¿Cómo se distribuye esa exposición crítica por sector y tipo de servicio (administración, sanidad, energía, etc.)?	G1	M1	NIS2 – clasificación de entidades esenciales e importantes; normativa sectorial crítica	La diferenciación sectorial permite priorizar acciones conforme al impacto en servicios esenciales. [web:7] [web:10] [web:12]
Q1-G2-TIME	¿Cuál es el tiempo medio de mitigación de vulnerabilidades con Threat=Active o Mass en los sectores regulados?	G2	M2	NIS2 – obligación de gestión continua de riesgos y respuesta a incidentes; guías ENISA sobre vulnerabilidades	La rapidez de mitigación de vulnerabilidades explotadas es un indicador directo de diligencia debida. [web:7] [web:13]

Q2-G2-DEADLINE	¿Qué porcentaje de estas vulnerabilidades explotadas supera el plazo objetivo de mitigación definido por el regulador?	G2	M2, M3	NIS2 – obligaciones de medidas proporcionadas y continuas; normativa nacional sobre operadores críticos	Permite verificar el cumplimiento efectivo de plazos de mitigación establecidos en normativa o acuerdos sectoriales. [web:7] [web:12]
Q1-G3-ESS	¿Qué porcentaje de vulnerabilidades críticas permanece sin mitigación en servicios esenciales más allá del plazo permitido?	G3	M3	NIS2 – requisitos específicos para entidades esenciales; legislación sobre seguridad nacional e infraestructuras críticas	Conecta la gestión de vulnerabilidades con la continuidad de servicios esenciales y la seguridad nacional. [web:7] [web:10] [web:12]
Q2-G3-IMPACT	¿En qué medida estas vulnerabilidades afectan a sistemas cuyo fallo impactaría en la vida humana o la seguridad física?	G3	M3	NIS2; regulaciones sectoriales (sanidad, transporte, energía)	El uso de métricas Supplemental de CVSS v4.0 permite identificar impactos en safety y vida humana. [web:1] [web:10]
Q1-G4-COVER	¿Qué porcentaje de vulnerabilidades relevantes para el país dispone de scoring CVSS v4.0 completo (Base, Threat, Environmental)?	G4	M4	NIS2 – cooperación e intercambio de información; EUVD (ENISA)	La cobertura de scoring robusto es un prerrequisito para reporting significativo y coordinación transfronteriza. [web:7] [web:13]

Q2-G4-TRACE	¿Qué porcentaje de incidentes notificados está vinculado explícitamente a métricas CVSS en el proceso de análisis y notificación?	G4	M5	NIS2 – obligaciones de notificación de incidentes; directrices ENISA	Asegura coherencia entre la cuantificación de vulnerabilidades y la clasificación de incidentes comunicados a autoridades. [web:7] [web:13]
Q3-G4-QUALITY	¿Hasta qué punto los procesos de scoring y reporting CVSS son auditables y consistentes entre operadores y sectores?	G4	M4, M5	NIS2; normativa nacional de supervisión y auditoría en ciberseguridad	La auditabilidad de las métricas CVSS se alinea con las exigencias de supervisión y sanción en caso de incumplimiento. [web:7] [web:12]

2. Uso de este mapeo

Esta tabla sirve para:

- Demostrar trazabilidad entre medición técnica y cumplimiento normativo.
- Guiar la redacción de guías nacionales y sectoriales que exijan indicadores concretos.
- Priorizar el desarrollo de capacidades de datos donde la falta de métricas vulnera o debilita el cumplimiento de NIS2. [web:7][web:13]